Phase D: Risk Matrix and Threat Model

Independent Extension | Risk Assessment & Threat Modeling for Exposed S3 Data

Prepared by Titilayo Yusuf | Cloud Security Engineer Internship

1. Objective and scope

This document models how an attacker could reach sensitive data held in Amazon S3, using the misconfigured environment from the Phase B homelab (CloudGoat *cloud_breach_s3*, which created a cardholder data bucket) as the reference scenario. Each asset is mapped to its threats, the impact if the threat succeeds, a qualitative likelihood and impact rating, and the mitigation that reduces the risk.

2. Assets in scope

Asset	Description	Why it matters
Customer Data Bucket	S3 bucket holding cardholder / customer records (lab: cg-cardholder-data-bucket-*).	Primary target; contains the most sensitive data.
Logs Bucket	S3 bucket holding CloudTrail and access logs.	Evidence for detection and investigation; also leaks reconnaissance data if exposed.
Web-facing EC2 + instance role	Public instance running a reverse proxy, with an IAM role attached.	Entry point; its role credentials grant access to S3.
IAM roles, users and keys	Identities that can call S3 APIs.	Over-broad permissions turn one stolen credential into full data access.

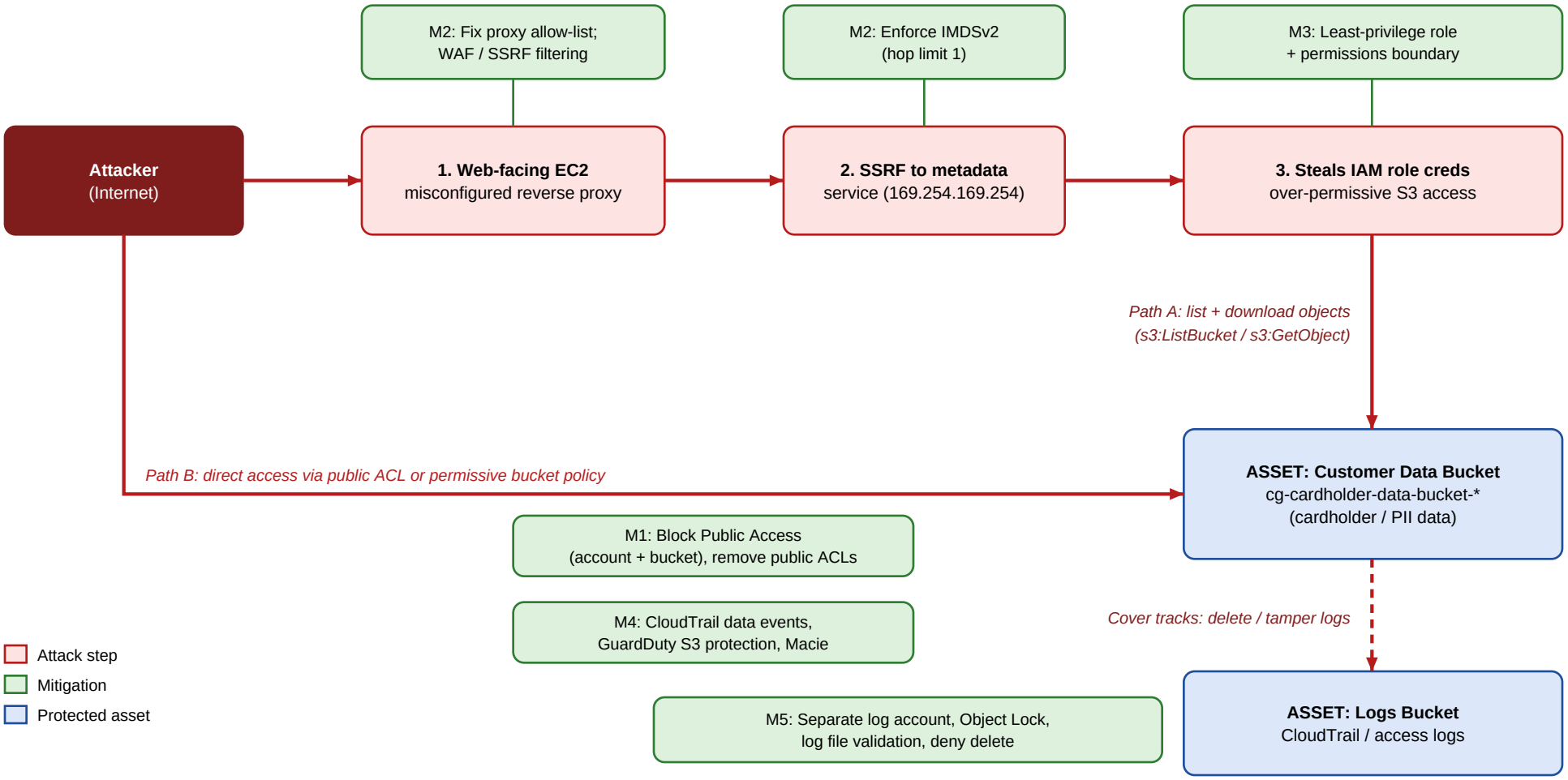
3. Rating method

Likelihood and impact are each rated **Low (1)**, **Medium (2)** or **High (3)**. Risk is the product: **1-2 = Low**, **3-4 = Medium**, **6 = High**, **9 = Critical**. Ratings are qualitative judgments for a lab-based exercise, not measured probabilities.

4. Risk matrix: assets, threats, impacts, mitigations

ID	Asset	Threat / attack scenario	Consequence	Likelihood	Impact	Risk	Mitigation
T1	**Customer Data Bucket**	Bucket ACL or policy grants public or *AuthenticatedUsers* access; anyone can list and download objects.	Exposure of cardholder / PII data; regulatory breach; reputational harm.	**Medium**	**High**	**High**	Enable S3 Block Public Access (account + bucket); remove public ACLs; review with IAM Access Analyzer.
T2	**Web-facing EC2 + IAM role**	SSRF through a misconfigured reverse proxy reaches the instance metadata service and returns temporary role credentials.	Attacker acts as the instance role and reaches S3 data.	**Medium**	**High**	**High**	Enforce IMDSv2 (HttpTokens=required, hop limit 1); block link-local addresses in the proxy; add WAF rules.
T3	**IAM role / permissions**	Role carries broad S3 permissions (e.g. s3:* on *), so stolen credentials can read every bucket.	Blast radius covers all buckets, not only the intended one.	**High**	**High**	**Critical**	Least-privilege policy scoped to the bucket ARN and required actions; permissions boundary; validate policies with Access Analyzer.
T4	**Customer Data Bucket**	Bulk download of objects goes unnoticed because object-level activity is not logged or alerted on.	Long dwell time; data loss discovered late.	**Medium**	**High**	**High**	CloudTrail S3 data events; GuardDuty S3 protection; Macie for sensitive-data discovery; alarms on unusual GetObject volume.
T5	**Logs Bucket**	Attacker with write or delete rights removes or alters logs to hide activity.	Loss of forensic evidence; incident scope cannot be proven.	**Medium**	**Medium**	**Medium**	Store logs in a separate account; S3 Object Lock; CloudTrail log file validation; explicit deny on delete.
T6	**Logs Bucket**	Logs bucket readable by too many principals or public; logs reveal bucket names, IPs and roles.	Reconnaissance data helps later attacks.	**Low**	**Medium**	**Low**	Block Public Access; restrict read to the security team role; bucket policy with explicit deny.
T7	**Customer Data Bucket**	Objects stored without encryption or with a broadly shared key, so access to the bucket means access to readable data.	Data readable after any access-control failure.	**Medium**	**Medium**	**Medium**	Default SSE-KMS with a key policy limited to named roles; enforce TLS (aws:SecureTransport) in bucket policy.
T8	**IAM users / access keys**	Long-lived access keys leak (committed to a repo, left in shared files) and are used against S3.	Persistent unauthorized access outside the VPC.	**Medium**	**High**	**High**	Prefer roles and SSO over static keys; rotate and remove unused keys; secret scanning on repos; MFA for human users.

5. Threat model: attacker paths to exposed S3 data

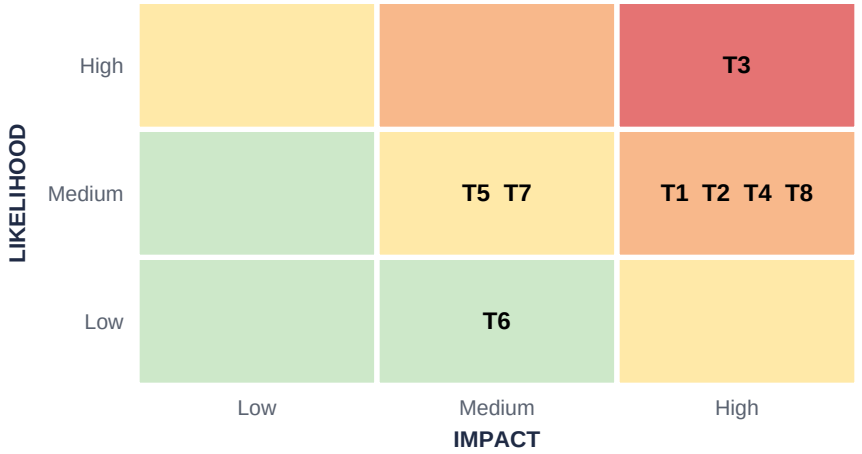


Path A chains an application flaw into credential theft (as in the CloudGoat scenario). **Path B** is the simpler case of a bucket exposed directly to the internet. Both end at the same asset, which is why mitigations M1 to M3 are preventive and M4 and M5 are detective and evidentiary.

7. Recommended mitigations (in priority order)

Rank	Mitigation	Addresses	Effort
1	**Least-privilege IAM**: scope roles to the specific bucket ARN and actions; add permissions boundaries.	T3, T2, T8	Medium
2	**Enable S3 Block Public Access** at account and bucket level; remove public ACLs.	T1, T6	Low
3	**Enforce IMDSv2** and harden the reverse proxy against SSRF.	T2	Low
4	**Detective controls**: CloudTrail data events, GuardDuty S3 protection, Macie, alarms.	T4	Medium
5	**Encrypt with SSE-KMS** and require TLS via bucket policy.	T7	Low
6	**Protect the logs**: separate account, Object Lock, log file validation.	T5, T6	Medium
7	**Remove static keys**: use roles / SSO, rotate keys, scan repos for secrets.	T8	Low

6. Likelihood vs impact



8. Conclusion

The highest risk (T3, Critical) is excessive IAM permission, because it determines how much an attacker gains once any credential is obtained. Applying Block Public Access, IMDSv2 and least-privilege roles removes or lowers most of the High-rated threats. Residual risk after these controls is expected to be Low to Medium, driven mainly by detection gaps and insider misuse, which M4 and M5 address.